MechZone AWS

Incident Investigation

Cloud Security Forensics Write-Up

Date of Incident: 2023-06-01 | Region: us-east-1 | Account: 670756667180

1. Background

MechZone's cloud-ops-intern fell victim to a phishing attack, inadvertently handing an attacker access to the company's AWS environment. The goal of this investigation is to trace exactly what the attacker did once they gained access i.e identifying the compromised identity, the malicious resources they deployed, and the backdoors they left behind.

We conduct this investigation by analysing AWS CloudTrail logs, which record every API call made within the environment. Using jq, we filter and parse the JSON log files to reconstruct the full attack timeline.

2. Identifying the Compromised Identity

The first thing we need to establish is who was compromised and what their identity looks like in AWS. Since we already know the intern's username is cloud-ops-intern, we query the CloudTrail logs to pull their ARN (Amazon Resource Name) i.e a unique identifier that AWS assigns to every user, role, and resource.

We run the following jq filter to select all events tied to cloud-ops-intern and extract their ARN:

```
------------------------------------------------------------
  STEP 1: Identifying the compromised identity
  Looking up the ARN for cloud-ops-intern...
------------------------------------------------------------
arn:aws:iam::670756667180:user/cloud-ops-intern

  >>> Press ENTER to continue to next step...
```

Figure 1 i.e ARN of the compromised identity: arn:aws:iam::670756667180:user/cloud-ops-intern

This tells us the account ID is 670756667180 and confirms the intern is a standard IAM user. This ARN becomes our anchor point for the rest of the investigation.

3. Mapping All Activity Under the Compromised Account

Now that we have the identity, we pull every eventSource, eventName, and eventTime tied to that user. This gives us a bird's eye view of all actions taken under their account i.e both legitimate reconnaissance and malicious activity.

```
------------------------------------------------------------
  STEP 2: What did cloud-ops-intern do?
  Fetching all eventSource, eventName and timestamps...
------------------------------------------------------------
2023-06-01T01:02:55Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:03:41Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:03:56Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:04:41Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:04:56Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:05:42Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:05:54Z  health.amazonaws.com          DescribeEventAggregates
2023-06-01T01:05:54Z  health.amazonaws.com          DescribeEventAggregates
2023-06-01T01:05:56Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:06:42Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:06:57Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:07:42Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:07:57Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:08:43Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:08:57Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:09:18Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:09:19Z  cloudformation.amazonaws.com  GetTemplateSummary
2023-06-01T01:09:20Z  notifications.amazonaws.com   ListNotificationHubs
2023-06-01T01:09:21Z  health.amazonaws.com          DescribeEventAggregates
2023-06-01T01:09:21Z  health.amazonaws.com          DescribeEventAggregates
2023-06-01T01:11:05Z  cloudformation.amazonaws.com  CreateStack
2023-06-01T01:11:05Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:11:05Z  cloudformation.amazonaws.com  DescribeStacks
2023-06-01T01:11:05Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:11:08Z  iam.amazonaws.com             CreateUser
2023-06-01T01:11:08Z  iam.amazonaws.com             GetUser
2023-06-01T01:11:09Z  ec2.amazonaws.com             CreateSecurityGroup
2023-06-01T01:11:09Z  iam.amazonaws.com             GetUserPolicy
2023-06-01T01:11:14Z  ec2.amazonaws.com             AuthorizeSecurityGroupEgress
2023-06-01T01:11:14Z  ec2.amazonaws.com             AuthorizeSecurityGroupIngress
2023-06-01T01:11:14Z  ec2.amazonaws.com             CreateTags
2023-06-01T01:11:14Z  ec2.amazonaws.com             RevokeSecurityGroupEgress
2023-06-01T01:11:14Z  ec2.amazonaws.com             RevokeSecurityGroupEgress
2023-06-01T01:11:18Z  ec2.amazonaws.com             CreateTags
2023-06-01T01:11:18Z  ec2.amazonaws.com             RunInstances
2023-06-01T01:11:18Z  ec2.amazonaws.com             RunInstances
2023-06-01T01:11:19Z  ec2.amazonaws.com             RunInstances
2023-06-01T01:11:20Z  ec2.amazonaws.com             CreateTags
2023-06-01T01:11:44Z  iam.amazonaws.com             PutUserPolicy
2023-06-01T01:12:07Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:12:07Z  cloudformation.amazonaws.com  ListStacks
2023-06-01T01:13:07Z  cloudformation.amazonaws.com  DescribeStackEvents
2023-06-01T01:13:07Z  cloudformation.amazonaws.com  ListStacks
```

Figure 2 i.e Full event list for cloud-ops-intern showing eventSource, eventName, and timestamps

Looking at the full event list we can immediately see a suspicious sequence unfold at around 01:11Z. This is the starting point of all our follow-up queries i.e every finding below is rooted in this event timeline.

4. Malicious Compute Resources Deployed

With EC2 RunInstances events visible in the timeline, we dig deeper to find out exactly how many instances were launched and what they look like. We query the responseElements of the RunInstances events, which contain the actual instance IDs assigned by AWS.

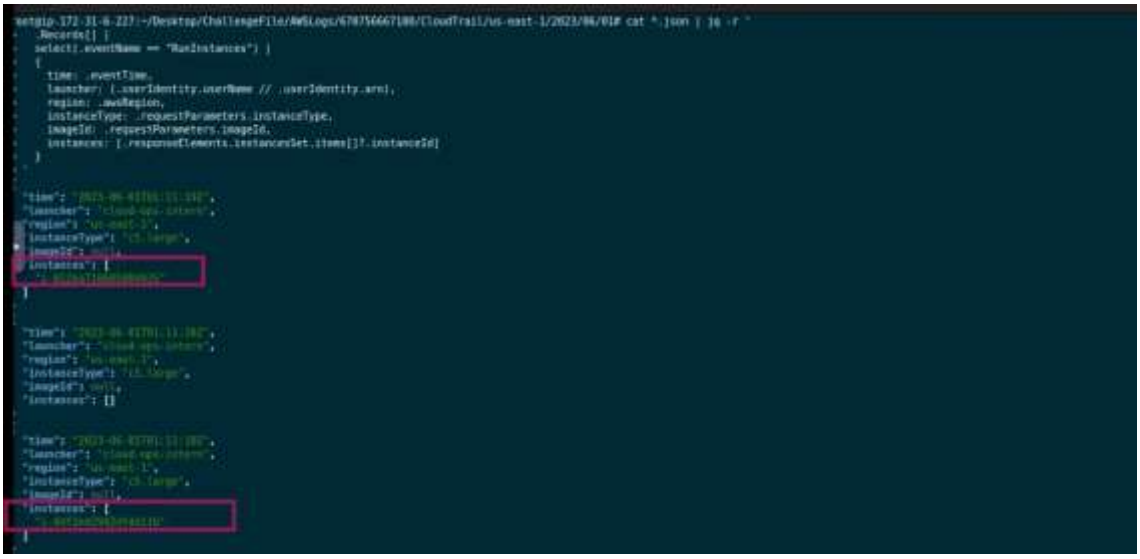


Figure 3 i.e RunInstances events showing deployed EC2 instance IDs

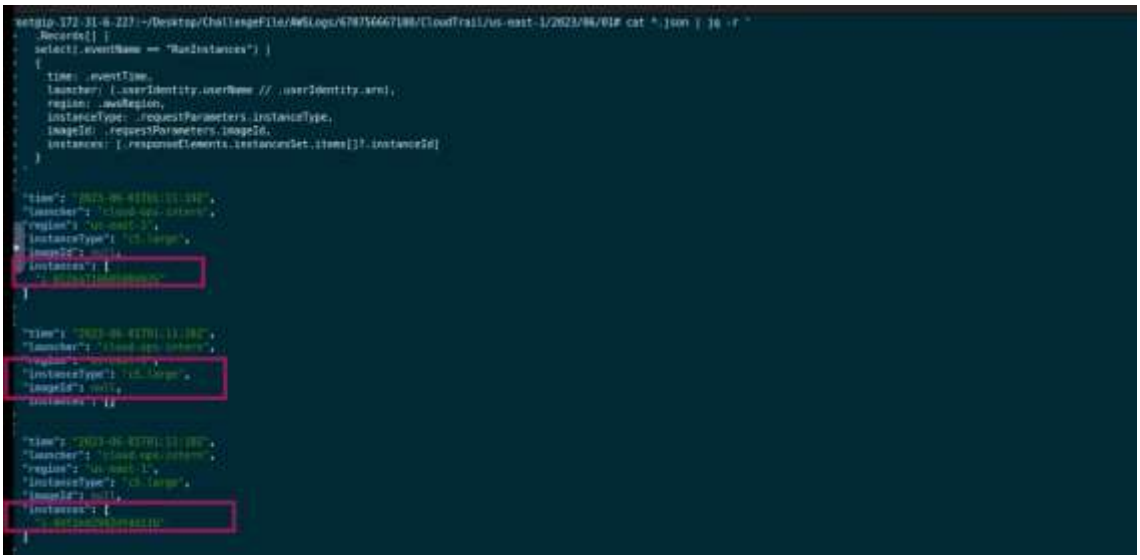


Figure 4 i.e Instance type confirmed as c5.large across all RunInstances events

This reveals 2 confirmed EC2 instances were deployed:

- i-0126a710605884935
- i-0df2ed2942dfdd11b

Both were c5.large instance types i.e a compute-optimised instance class. This is a strong indicator of crypto mining, as attackers frequently spin up high-compute instances in victim accounts to mine cryptocurrency at the victim's expense.

5. Attack Timeline Reconstruction

Pulling the full event timeline for the intern's account allows us to reconstruct exactly how the attack unfolded. The sequence of events shows a highly automated, deliberate attack executed in under 20 minutes.

```
2023-06-01T01:09:10Z    notifications.amazonaws.com     ListNotificationHubs
2023-06-01T01:09:10Z    s3.amazonaws.com        GetAccountPublicAccessBlock
2023-06-01T01:09:10Z    s3.amazonaws.com        GetBucketAcl
2023-06-01T01:09:10Z    s3.amazonaws.com        GetBucketOwnershipControls
2023-06-01T01:09:10Z    s3.amazonaws.com        GetBucketPolicyStatus
2023-06-01T01:09:10Z    s3.amazonaws.com        GetBucketPublicAccessBlock
2023-06-01T01:09:10Z    s3.amazonaws.com        GetBucketVersioning
2023-06-01T01:09:10Z    s3.amazonaws.com        ListAccessPoints
2023-06-01T01:09:10Z    s3.amazonaws.com        ListBuckets
2023-06-01T01:09:11Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:11Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:13Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:13Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:18Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:09:19Z    cloudformation.amazonaws.com    GetTemplateSummary
2023-06-01T01:09:20Z    notifications.amazonaws.com     ListNotificationHubs
2023-06-01T01:09:21Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:09:21Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:09:21Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:21Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:22Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:22Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:10:25Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:10:25Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    CreateStack
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    DescribeStacks
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:11:08Z    iam.amazonaws.com       CreateUser
2023-06-01T01:11:08Z    iam.amazonaws.com       GetUser
2023-06-01T01:11:09Z    ec2.amazonaws.com       CreateSecurityGroup
2023-06-01T01:11:09Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:09Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:09Z    iam.amazonaws.com       GetUserPolicy
2023-06-01T01:11:14Z    ec2.amazonaws.com       AuthorizeSecurityGroupEgress
2023-06-01T01:11:14Z    ec2.amazonaws.com       AuthorizeSecurityGroupIngress
2023-06-01T01:11:14Z    ec2.amazonaws.com       CreateTags
2023-06-01T01:11:14Z    ec2.amazonaws.com       RevokeSecurityGroupEgress
2023-06-01T01:11:14Z    ec2.amazonaws.com       RevokeSecurityGroupEgress
2023-06-01T01:11:18Z    ec2.amazonaws.com       CreateTags
2023-06-01T01:11:18Z    ec2.amazonaws.com       RunInstances
2023-06-01T01:11:18Z    ec2.amazonaws.com       RunInstances
2023-06-01T01:11:19Z    ec2.amazonaws.com       RunInstances
```

Figure 5 i.e Full attack timeline showing CreateStack, CreateUser, security group, and RunInstances events

Key moments in the timeline:

- 01:05Z i.e cloudformation.amazonaws.com CreateStack i.e malicious infrastructure deployed via CloudFormation
- 01:08Z i.e iam.amazonaws.com CreateUser + GetUser i.e backdoor identity created
- 01:09Z i.e ec2.amazonaws.com CreateSecurityGroup i.e custom firewall prepared
- 01:11Z i.e ec2.amazonaws.com AuthorizeSecurityGroupIngress/Egress i.e inbound SSH access opened
- 01:11Z i.e ec2.amazonaws.com RunInstances x2 i.e compute instances launched
- 01:11Z i.e iam.amazonaws.com PutUserPolicy i.e permissions attached to backdoor user

6. Security Group i.e Firewall Rules Analysis

Before the instances were launched, the attacker created a security group and added inbound rules to it. Security groups act as virtual firewalls in AWS, controlling what traffic can reach an instance. We query the AuthorizeSecurityGroupIngress event to see exactly what access was opened up.

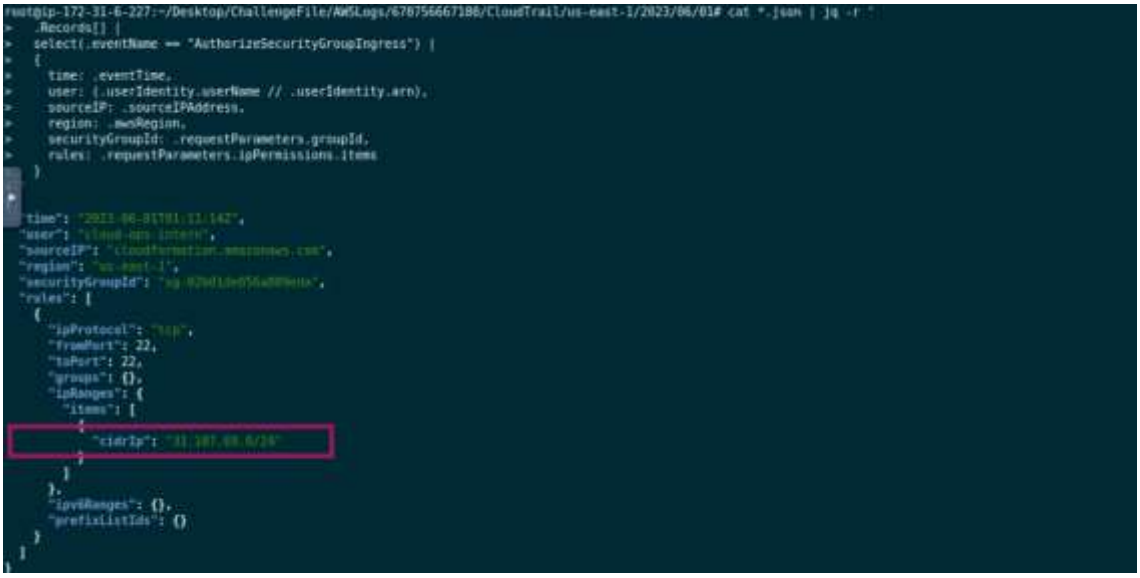


Figure 6 i.e AuthorizeSecurityGroupIngress showing port 22 TCP opened for CIDR 31.187.69.0/24

The results reveal a very deliberate configuration:

- Security Group ID: sg-02b01de056a809eda
- Protocol: tcp
- Port: 22 (SSH i.e remote access)
- Allowed CIDR: 31.187.69.0/24

Rather than opening access to the entire internet (0.0.0.0/0) which would be noisy and easily detectable, the attacker restricted SSH access exclusively to their own IP subnet i.e giving themselves a clean backdoor into both instances while avoiding obvious red flags.

7. Malicious IAM Identity Created

Alongside the compute resources, a CreateUser event was spotted in the timeline. Attackers commonly create a new IAM user as a persistence mechanism i.e even if the compromised account (cloud-ops-intern) is disabled or its credentials rotated, the backdoor user remains active.

```
2023-06-01T01:09:19Z    cloudformation.amazonaws.com    GetTemplateSummary
2023-06-01T01:09:20Z    notifications.amazonaws.com     ListNotificationHubs
2023-06-01T01:09:21Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:09:21Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:09:21Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:21Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:22Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:09:22Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:10:25Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:10:25Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    CreateStack
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    DescribeStacks
2023-06-01T01:11:05Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:11:08Z    iam.amazonaws.com       CreateUser
2023-06-01T01:11:08Z    iam.amazonaws.com       GetUser
2023-06-01T01:11:09Z    ec2.amazonaws.com       CreateSecurityGroup
2023-06-01T01:11:09Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:09Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:09Z    iam.amazonaws.com       GetUserPolicy
2023-06-01T01:11:14Z    ec2.amazonaws.com       AuthorizeSecurityGroupEgress
2023-06-01T01:11:14Z    ec2.amazonaws.com       AuthorizeSecurityGroupIngress
2023-06-01T01:11:14Z    ec2.amazonaws.com       CreateTags
2023-06-01T01:11:14Z    ec2.amazonaws.com       RevokeSecurityGroupEgress
2023-06-01T01:11:14Z    ec2.amazonaws.com       RevokeSecurityGroupEgress
2023-06-01T01:11:18Z    ec2.amazonaws.com       CreateTags
2023-06-01T01:11:18Z    ec2.amazonaws.com       RunInstances
2023-06-01T01:11:18Z    ec2.amazonaws.com       RunInstances
2023-06-01T01:11:19Z    ec2.amazonaws.com       RunInstances
2023-06-01T01:11:20Z    ec2.amazonaws.com       CreateTags
2023-06-01T01:11:20Z    ec2.amazonaws.com       SharedSnapshotVolumeCreated
2023-06-01T01:11:22Z    ec2.amazonaws.com       SharedSnapshotVolumeCreated
2023-06-01T01:11:33Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:11:33Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:11:33Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:33Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:35Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:35Z    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:11:44Z    iam.amazonaws.com       PutUserPolicy
2023-06-01T01:11:54Z    s3.amazonaws.com        GetBucketAcl
2023-06-01T01:12:07Z    cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:12:07Z    cloudformation.amazonaws.com    ListStacks
2023-06-01T01:12:10Z    health.amazonaws.com    DescribeEventAggregates
```

Figure 7 i.e CreateUser event in the timeline confirming a new IAM user was created

```
.Records[] |
select(.eventSource == "iam.amazonaws.com" and .eventName == "CreateUser") |
{
  time: .eventTime,
  createdBy: (.userIdentity.userName // .userIdentity.arn),
  newUsername: .requestParameters.userName,
  sourceIP: .sourceIPAddress,
  region: .awsRegion
}
.

"time": "2023-06-01T01:11:08Z",
"createdBy": "cloud-ops-intern",
"newUsername": "devops-admin",
"sourceIP": "cloudformation.amazonaws.com",
"region": "us-east-1"
```

Figure 8 i.e CreateUser details revealing the malicious username: devops-admin

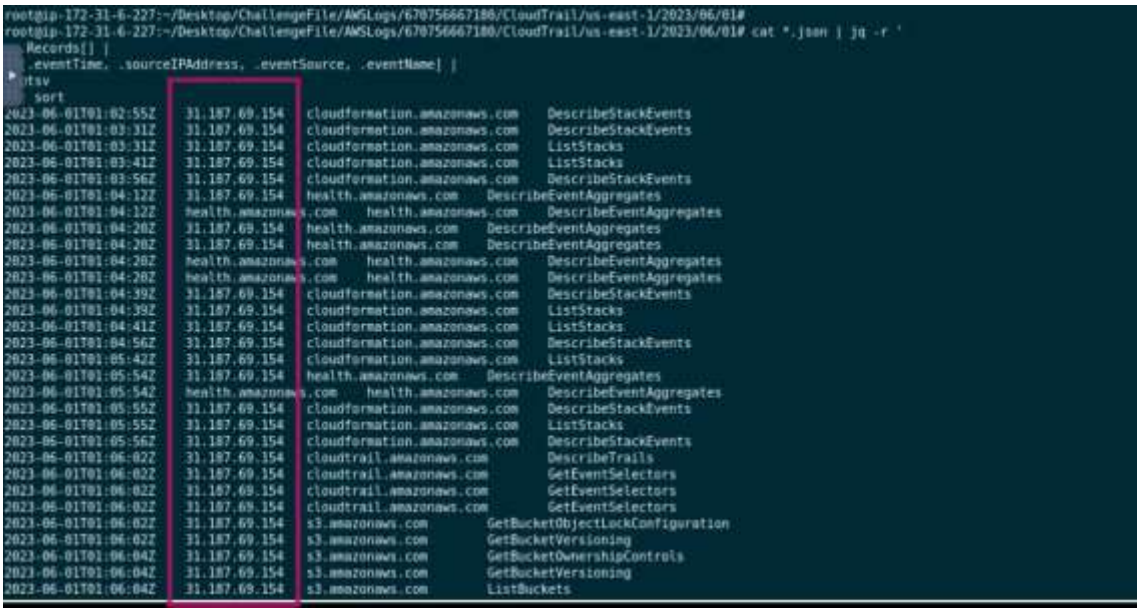
The query reveals:

- New Username: devops-admin
- Created By: cloud-ops-intern (under attacker's control)
- Time: 2023-06-01T01:11:08Z

The name devops-admin is intentionally chosen to blend in with legitimate admin accounts. Shortly after creation, a PutUserPolicy event confirms that permissions were attached to this user, giving the attacker a fully operational backdoor identity inside the environment.

8. Attack Origin i.e Source IP Analysis

Finally, we correlate the source IP address across all malicious events. By querying the sourceIPAddress field across CreateUser, RunInstances, and AuthorizeSecurityGroupIngress events, we can identify exactly where the attack originated from.



```
root@ip-172-31-6-227:~/Desktop/ChallengeFile/AWSLogs/670756667180/CloudTrail/us-east-1/2023/06/01#
root@ip-172-31-6-227:~/Desktop/ChallengeFile/AWSLogs/670756667180/CloudTrail/us-east-1/2023/06/01# cat *.json | jq -r '
  .Records[] |
  .eventTime, .sourceIPAddress, .eventSource, .eventName| |
  @tsv
  | sort
2023-06-01T01:02:55Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:03:31Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:03:31Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:03:41Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:03:56Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:04:12Z    31.187.69.154   health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:12Z    health.amazonaws.com    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:20Z    31.187.69.154   health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:20Z    31.187.69.154   health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:28Z    health.amazonaws.com    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:28Z    health.amazonaws.com    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:04:39Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:04:39Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:04:41Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:04:56Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:05:42Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:05:54Z    31.187.69.154   health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:05:54Z    health.amazonaws.com    health.amazonaws.com    DescribeEventAggregates
2023-06-01T01:05:55Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:05:55Z    31.187.69.154   cloudformation.amazonaws.com    ListStacks
2023-06-01T01:05:56Z    31.187.69.154   cloudformation.amazonaws.com    DescribeStackEvents
2023-06-01T01:06:02Z    31.187.69.154   cloudtrail.amazonaws.com        DescribeTrails
2023-06-01T01:06:02Z    31.187.69.154   cloudtrail.amazonaws.com        GetEventSelectors
2023-06-01T01:06:02Z    31.187.69.154   cloudtrail.amazonaws.com        GetEventSelectors
2023-06-01T01:06:02Z    31.187.69.154   cloudtrail.amazonaws.com        GetEventSelectors
2023-06-01T01:06:02Z    31.187.69.154   s3.amazonaws.com        GetBucketObjectLockConfiguration
2023-06-01T01:06:02Z    31.187.69.154   s3.amazonaws.com        GetBucketVersioning
2023-06-01T01:06:04Z    31.187.69.154   s3.amazonaws.com        GetBucketOwnershipControls
2023-06-01T01:06:04Z    31.187.69.154   s3.amazonaws.com        GetBucketVersioning
2023-06-01T01:06:04Z    31.187.69.154   s3.amazonaws.com        ListBuckets
```

Figure 9 i.e Source IP 31.187.69.154 present across all malicious events

Every suspicious action i.e the CreateStack, RunInstances, AuthorizeSecurityGroupIngress, and CreateUser i.e originates from a single IP address: 31.187.69.154. This is the attacker's IP. It is also the same subnet (31.187.69.0/24) they whitelisted in the security group, which confirms this was a deliberate, coordinated attack from a single threat actor.

9. Summary of Findings

The following table summarises all key findings from the investigation:

Finding	Value
Compromised ARN	`arn:aws:iam::670756667180:user/cloud-ops-intern`
Attack Origin IP	`31.187.69.154`
Malicious Service	`ec2.amazonaws.com (via CloudFormation)`
Instances Deployed	`2 (i-0126a710605884935, i-0df2ed2942dfdd11b)`
Instance Type	`c5.large`
Security Group CIDR	`31.187.69.0/24`
Port Opened	`22 (SSH)`
Protocol	`tcp`
Backdoor IAM User	`devops-admin`

10. Conclusion

The attacker used a phishing link to steal the intern's AWS credentials and then executed a fully automated attack via CloudFormation i.e deploying EC2 instances for likely crypto mining, opening SSH access exclusively for themselves, and creating a hidden devops-admin IAM user for persistent access. The entire attack was carried out in under 20 minutes from a single IP address: 31.187.69.154.

Immediate remediation steps should include:

- Disable and rotate credentials for cloud-ops-intern immediately
- Delete the devops-admin IAM user and all associated access keys
- Terminate EC2 instances i-0126a710605884935 and i-0df2ed2942dfdd11b
- Delete security group sg-02b01de056a809eda
- Audit all CloudFormation stacks created on 2023-06-01 and roll back
- Block IP 31.187.69.0/24 at the network perimeter
- Enable MFA for all IAM users and review IAM policies